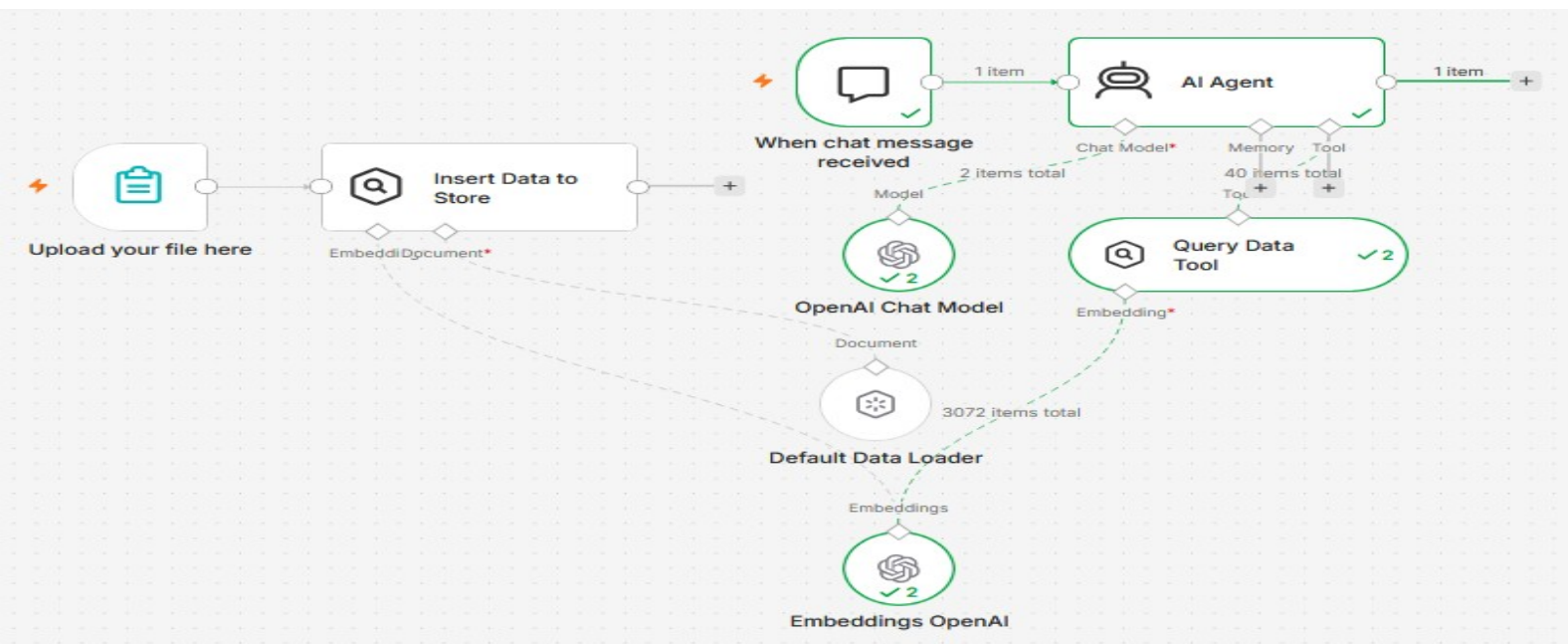


TFC

ASISTENTE DE CIBERSEGURIDAD Y COMPLIANCE BASADO EN IA Y RAG



Armand Codina
ID Scola: EX0092

Programa #Impact

Fundación
GOODJOB

Junio 2026

Índice

1. Introducción.....	3
2. Fase 1 - Diseño del asistente.....	4
2.1 Problema y objetivo.....	4
2.2 Tecnologías elegidas.....	4
2.3 Arquitectura del sistema.....	5
2.4 Flujo de las 4 capacidades.....	6
2.4.1 Capacidad 1 - Análisis de políticas de seguridad.....	6
2.4.2 Capacidad 2 - Detección de riesgos e incumplimientos.....	6
2.4.3 Capacidad 3 - Respuesta a preguntas de auditoría.....	6
2.4.4 Capacidad 4 - Propuestas de mejora.....	6
3. Fase 2 - Base de conocimiento (RAG).....	7
3.1 Normativas utilizadas.....	7
3.2 Configuración documental.....	7
3.3 Recuperación documental y procesamiento de contexto.....	8
3.4 Evidencias de funcionamiento.....	8
3.4.1 Evidencia 1: Corrección de la interpretación contextual del término ENS.....	9
3.4.2 Evidencia 2: Corrección y mejora de la recuperación documental del GDPR.....	11
4. Fase 3 - Construcción del asistente.....	13
4.1 Implementación de la Capacidad 1 - Análisis de políticas de seguridad.....	13
4.2 Implementación de la Capacidad 2 - Detección de riesgos e incumplimientos.....	14
4.3 Implementación de la Capacidad 3 - Respuesta a preguntas de auditoría.....	15
4.4 Implementación de la Capacidad 4 - Propuestas de mejora.....	16
5. Fase 4 - Demostración y entrega.....	18
6. Reflexión final.....	19
7. Anexos.....	20

1. Introducción

La evolución de la Inteligencia Artificial y los modelos de lenguaje ha permitido el desarrollo de asistentes capaces de automatizar tareas complejas relacionadas con análisis documental, auditoría y cumplimiento normativo.

En el ámbito de la ciberseguridad y el compliance, las organizaciones deben gestionar grandes volúmenes de documentación técnica y normativa, como políticas de seguridad, estándares internacionales y regulaciones legales. Este proceso puede resultar costoso y complejo cuando se realiza de forma manual.

El presente proyecto tiene como finalidad el diseño de un asistente de ciberseguridad basado en Inteligencia Artificial y técnicas RAG (Retrieval-Augmented Generation), orientado al análisis de políticas de seguridad y evaluación de cumplimiento frente a normativas como GDPR, ISO 27001 y ENS.

Para ello, se utilizarán tecnologías como OpenAI GPT-5-mini, automatización mediante n8n y almacenamiento documental en Google Drive, permitiendo construir un sistema capaz de consultar documentación, responder preguntas de auditoría y proponer mejoras de seguridad de forma automatizada.

2. Fase 1 - Diseño del asistente

2.1 Problema y objetivo

La empresa ficticia MIDTECH S.A. dispone de políticas de seguridad parcialmente definidas y necesita mejorar su capacidad de análisis y cumplimiento frente a normativas y estándares de ciberseguridad como GDPR, ISO 27001 y ENS.

Actualmente, la revisión manual de políticas y controles puede resultar lenta, compleja y propensa a errores, especialmente cuando se deben comparar múltiples normativas o detectar posibles carencias de seguridad.

El objetivo de este proyecto es diseñar un asistente basado en Inteligencia Artificial y técnicas RAG (Retrieval-Augmented Generation) capaz de analizar documentación corporativa, responder preguntas relacionadas con auditoría y compliance, detectar posibles incumplimientos normativos y proponer mejoras de seguridad de forma automatizada.

El asistente estará orientado a facilitar tareas de análisis documental, auditoría técnica y apoyo a responsables de seguridad y compliance mediante el uso de modelos LLM, automatización mediante n8n y recuperación contextual de información.

2.2 Tecnologías elegidas

Para la construcción del asistente se han seleccionado las siguientes tecnologías:

- Modelo LLM: OpenAI GPT-5-mini

Razón: modelo avanzado con buen rendimiento en español, capacidad de razonamiento y compatibilidad sencilla mediante API.

- Herramienta de orquestación: n8n Cloud

Razón: plataforma visual de automatización que permite integrar APIs, flujos IA y sistemas RAG sin necesidad de programación avanzada.

- Gestor documental: Google Drive

Razón: almacenamiento centralizado de normativas, políticas de seguridad y evidencias del proyecto, con integración sencilla para futuras consultas RAG.

- Repositorio y documentación: GitHub

Razón: almacenamiento público del proyecto, documentación técnica y versionado de prompts y diagramas.

2.3 Arquitectura del sistema

El sistema se ha diseñado utilizando una arquitectura basada en Retrieval-Augmented Generation (RAG), implementada mediante n8n y servicios de OpenAI para el procesamiento y recuperación contextual de información.

La fase de preparación de la base de conocimiento permite incorporar documentación normativa y evidencias de auditoría en formato texto. Estos documentos son procesados mediante un Data Loader y transformados en embeddings utilizando OpenAI Embeddings, almacenándose posteriormente en una base vectorial (Vector Store).

La orquestación principal de las consultas se realiza mediante n8n, OpenAI Embeddings y modelos GPT de OpenAI para el procesamiento y recuperación contextual de información. Cuando un usuario formula una pregunta a través del chat, el sistema genera una representación semántica de la consulta y realiza una búsqueda en la base vectorial para recuperar los fragmentos documentales más relevantes.

La información recuperada se incorpora como contexto al modelo de lenguaje, permitiendo generar respuestas fundamentadas en la documentación almacenada. Esta arquitectura facilita tareas de análisis documental, consultas de auditoría, identificación de incumplimientos y generación de propuestas de mejora relacionadas con compliance y ciberseguridad.

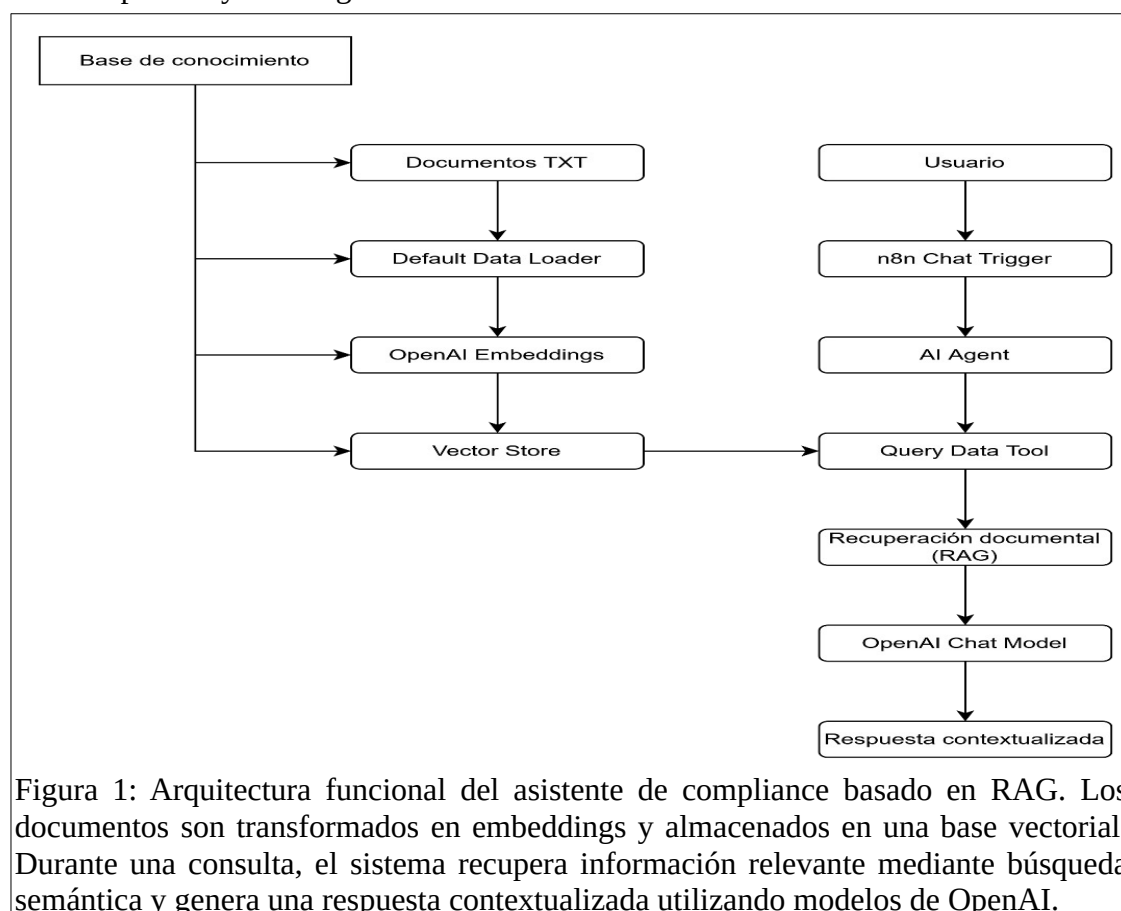


Figura 1: Arquitectura funcional del asistente de compliance basado en RAG. Los documentos son transformados en embeddings y almacenados en una base vectorial. Durante una consulta, el sistema recupera información relevante mediante búsqueda semántica y genera una respuesta contextualizada utilizando modelos de OpenAI.

2.4 Flujo de las 4 capacidades

2.4.1 Capacidad 1 - Análisis de políticas de seguridad

El usuario incorpora la política de MIDTECH a la base de conocimiento del asistente. El sistema la procesa mediante el flujo RAG y permite realizar consultas sobre su contenido para identificar áreas cubiertas, nivel de cobertura y ámbitos no contemplados.

Salida esperada:

Informe de análisis con al menos tres secciones: áreas cubiertas, nivel de cobertura y áreas ausentes. El análisis debe citar partes concretas del documento analizado.

2.4.2 Capacidad 2 - Detección de riesgos e incumplimientos

El asistente contrasta la política de MIDTECH con la normativa incluida en la base de conocimiento y devuelve los incumplimientos detectados en formato estructurado.

Salida esperada:

Gap analysis con una entrada por cada incumplimiento detectado.

2.4.3 Capacidad 3 - Respuesta a preguntas de auditoría

El usuario formula preguntas en lenguaje natural sobre la política de MIDTECH o sobre la documentación normativa incluida en la base de conocimiento. El asistente recupera el contexto más relevante mediante el mecanismo RAG y genera una respuesta fundamentada en la información disponible, estableciendo la relación entre la situación analizada y los requisitos normativos aplicables.

Salida esperada:

Respuesta fundamentada en la documentación recuperada, explicando la situación analizada y los requisitos normativos relacionados de forma clara y comprensible.

2.4.4 Capacidad 4 - Propuestas de mejora

A partir del análisis o de la conversación mantenida, el usuario solicita al asistente propuestas de mejora concretas y priorizadas para la política de MIDTECH.

Salida esperada:

Listado ordenado por prioridad con la mejora propuesta, normativa relacionada, prioridad y esfuerzo estimado.

3. Fase 2 - Base de conocimiento (RAG)

3.1 Normativas utilizadas

Para la construcción de la base de conocimiento del sistema RAG se utilizaron distintas normativas y estándares relacionados con ciberseguridad y compliance.

Las principales normativas incorporadas al sistema fueron las siguientes:

- Reglamento General de Protección de Datos (GDPR / RGPD)

Normativa europea orientada a la protección de datos personales y privacidad de la información.

- ISO/IEC 27001:2022

Estándar internacional de gestión de seguridad de la información utilizado como referencia para controles y buenas prácticas de seguridad.

- Esquema Nacional de Seguridad (ENS)

Marco normativo español orientado a garantizar la seguridad de la información en administraciones públicas y entidades relacionadas.

Estas normativas fueron utilizadas como base documental para las capacidades de análisis, detección de incumplimientos, auditoría conversacional y propuestas de mejora del asistente.

3.2 Configuración documental

La documentación utilizada para la base de conocimiento del asistente se organizó mediante Google Drive, permitiendo centralizar las normativas, documentos y evidencias necesarias para el proyecto.

Se creó una estructura de carpetas orientada a facilitar la organización documental y la futura integración con el sistema RAG.

La estructura principal utilizada fue la siguiente:

/Normativas
/MIDTECH
/Capturas
/Diagramas

Dentro de la carpeta “Normativas” se incorporaron los documentos PDF correspondientes a GDPR, ISO/IEC 27001:2022 y ENS (Esquema Nacional de Seguridad), que serán utilizados como base documental para las consultas y análisis del asistente.

Esta organización permitirá facilitar la indexación documental, recuperación contextual de información y futuras evidencias del funcionamiento del sistema.

3.3 Recuperación documental y procesamiento de contexto

Para proporcionar respuestas fundamentadas en documentación normativa y evidencias de auditoría, el asistente implementa una arquitectura RAG (Retrieval-Augmented Generation) desarrollada mediante n8n y modelos de OpenAI.

El proceso comienza con la carga de documentos en formato texto dentro del flujo de preparación de datos. Durante esta fase, los documentos son procesados por un Data Loader y transformados en embeddings mediante el modelo OpenAI Embeddings. Estos embeddings representan matemáticamente el contenido de los documentos y permiten realizar búsquedas semánticas sobre la información almacenada.

Los embeddings generados son almacenados en una base de conocimiento vectorial (Vector Store), que actúa como repositorio documental del asistente. Esta estructura permite recuperar fragmentos de información relevantes en función del significado de una consulta, en lugar de depender exclusivamente de coincidencias exactas de palabras clave.

Cuando un usuario realiza una consulta a través del chat, el flujo de recuperación genera primero el embedding correspondiente a la pregunta formulada. Posteriormente, el componente Query Data Tool consulta la base vectorial y recupera los fragmentos documentales más relevantes para dicha consulta.

La información recuperada se proporciona como contexto al agente de inteligencia artificial (AI Agent), que utiliza el modelo GPT para generar una respuesta fundamentada exclusivamente en el contenido almacenado en la base documental. Este mecanismo reduce las alucinaciones del modelo y mejora la precisión de las respuestas, ya que el sistema dispone de contexto específico relacionado con la pregunta realizada.

Gracias a esta arquitectura, la actualización de la base de conocimiento resulta sencilla, ya que únicamente es necesario incorporar nuevos documentos al proceso de carga para que queden disponibles en futuras consultas, sin necesidad de modificar la lógica principal del asistente.

3.4 Evidencias de funcionamiento

Pruebas funcionales del asistente de compliance mediante n8n y GPT-5-mini. Se añadió un contexto especializado mediante System Prompt para orientar las respuestas hacia normativas de ciberseguridad y compliance, permitiendo interpretar correctamente conceptos como ENS (Esquema Nacional de Seguridad), ISO 27001 y GDPR.

La prueba demuestra el funcionamiento del flujo conversacional y la generación de respuestas contextualizadas.

3.4.1 Evidencia 1: Corrección de la interpretación contextual del término ENS

Durante las primeras pruebas realizadas sobre el asistente, se observó que determinadas consultas especializadas podían ser interpretadas de forma incorrecta por el modelo de lenguaje al no disponer de contexto documental específico.

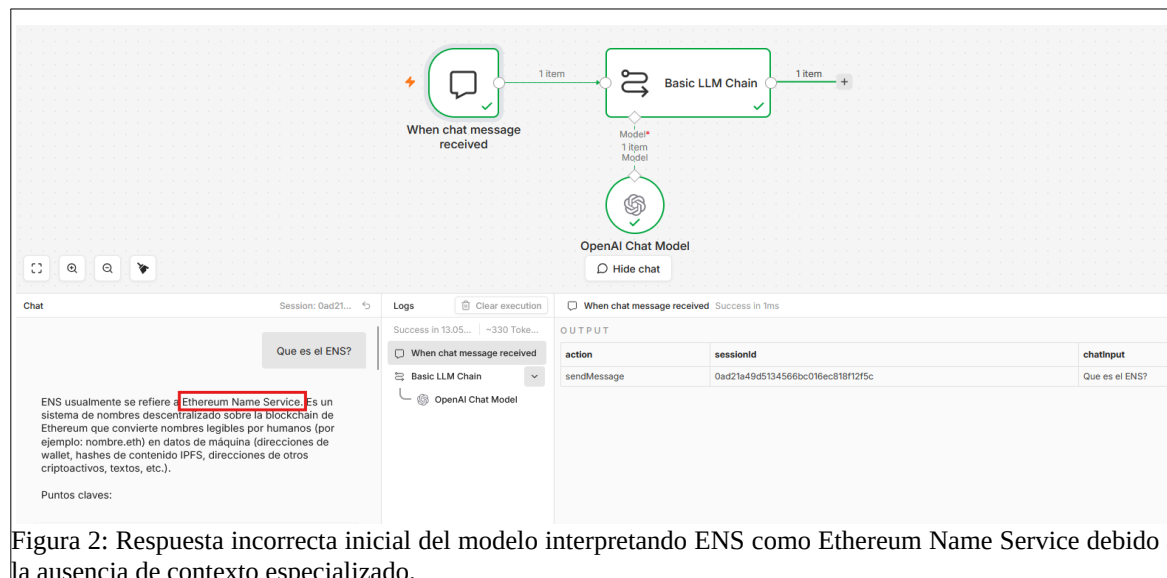


Figura 2: Respuesta incorrecta inicial del modelo interpretando ENS como Ethereum Name Service debido a la ausencia de contexto especializado.

Un ejemplo representativo fue la consulta sobre el término ENS. En ausencia de una base de conocimiento especializada, el modelo interpretó inicialmente las siglas ENS como Ethereum Name Service, proporcionando una respuesta ajena al ámbito de la ciberseguridad y el compliance.

Esta situación puso de manifiesto la necesidad de incorporar un mecanismo de recuperación documental capaz de aportar contexto especializado antes de la generación de la respuesta.



Figura 3: Funcionamiento de la arquitectura RAG durante una consulta sobre ENS.

Tras la implementación de la arquitectura RAG y la indexación de documentación normativa en una base vectorial, el asistente pasó a recuperar información contextual relevante antes de generar la respuesta. Como resultado, interpretó correctamente ENS como Esquema Nacional de Seguridad, generando respuestas alineadas con el ámbito de la ciberseguridad y el compliance.

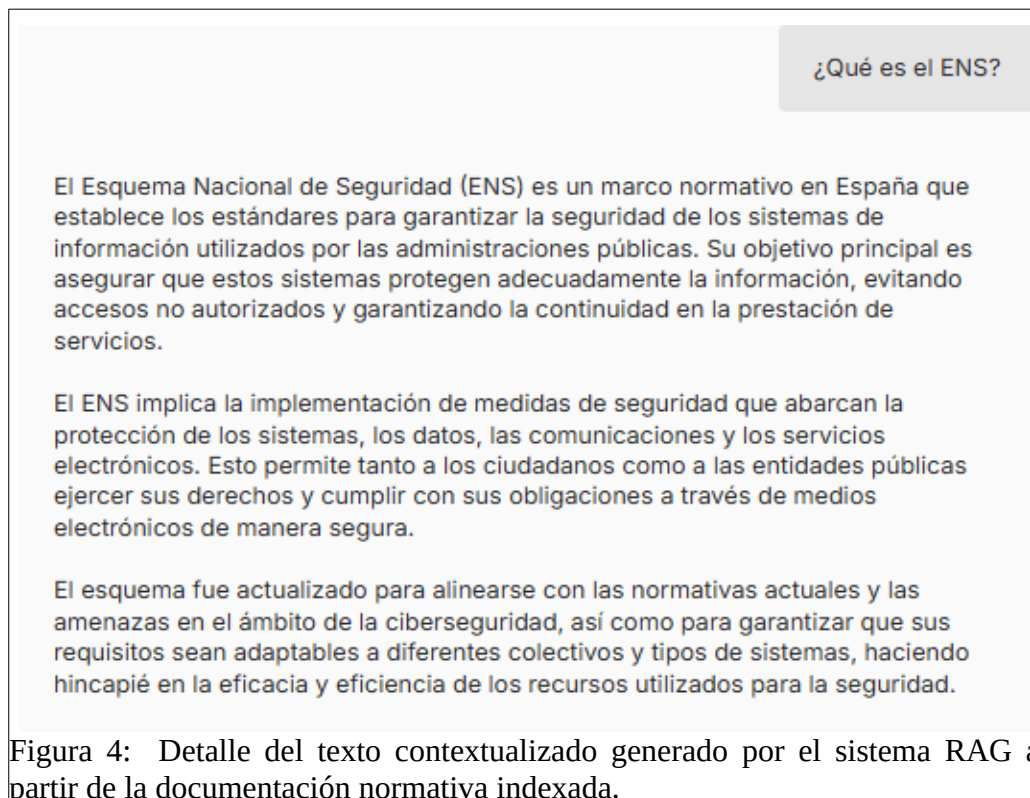


Figura 4: Detalle del texto contextualizado generado por el sistema RAG a partir de la documentación normativa indexada.

3.4.2 Evidencia 2: Corrección y mejora de la recuperación documental del GDPR.

Durante las pruebas de validación del asistente se detectó que las consultas relacionadas con el Reglamento General de Protección de Datos (GDPR) no proporcionaban respuestas precisas cuando se solicitaba información específica de artículos concretos, como el artículo 32 relativo a la seguridad del tratamiento.

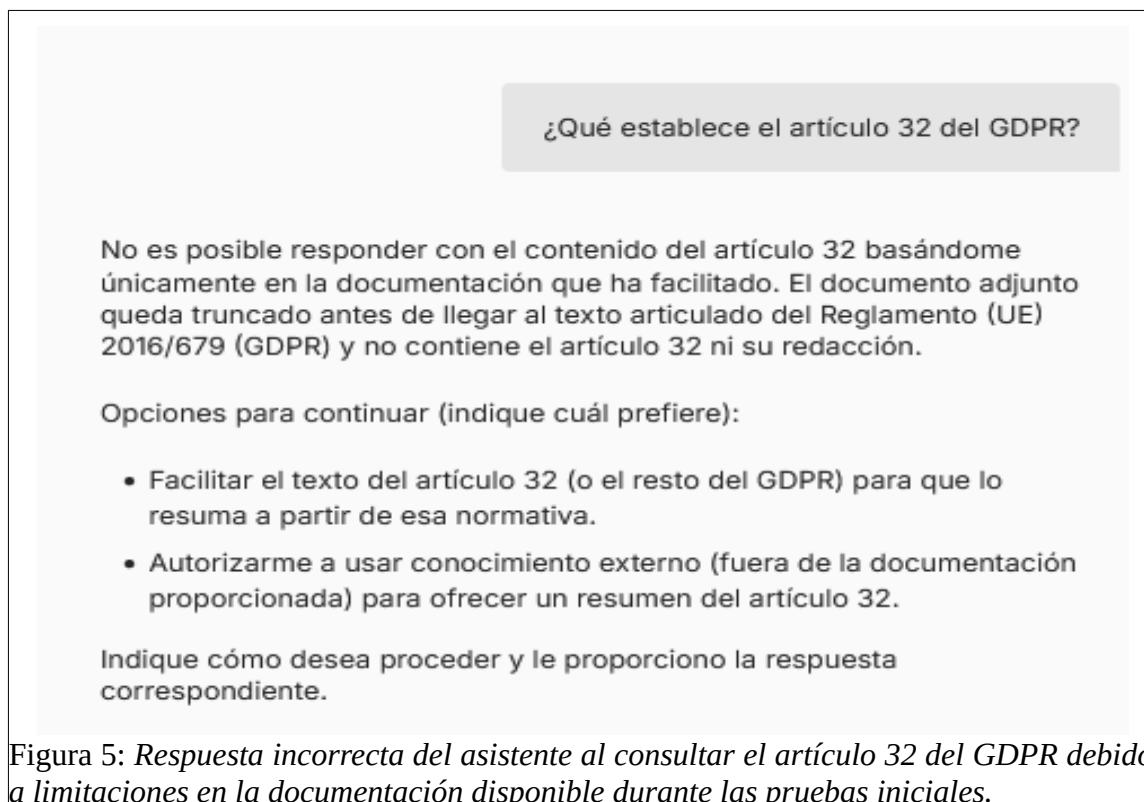


Figura 5: Respuesta incorrecta del asistente al consultar el artículo 32 del GDPR debido a limitaciones en la documentación disponible durante las pruebas iniciales.

Tras el análisis del flujo se identificaron dos problemas principales. En primer lugar, el documento utilizado como base documental no correspondía a la versión oficial completa del Reglamento (UE) 2016/679, sino a una referencia normativa incompleta, lo que impedía recuperar determinados artículos. En segundo lugar, la información disponible en la base de conocimiento resultaba insuficiente para responder consultas específicas sobre artículos concretos del GDPR.

Para corregir esta situación se sustituyó la documentación utilizada por la versión oficial completa del Reglamento (UE) 2016/679 y se volvió a indexar el contenido en la base vectorial. Tras este proceso, el sistema pudo recuperar correctamente los fragmentos documentales relevantes y utilizarlos como contexto para la generación de respuestas.

Una vez aplicadas estas mejoras, el asistente fue capaz de responder correctamente a consultas específicas sobre artículos concretos del GDPR. Los resultados obtenidos evidencian una mejora significativa en la recuperación de información normativa y en la calidad de las respuestas generadas.



Figura 6: Funcionamiento de la arquitectura RAG durante una consulta sobre el artículo 32 del GDPR.

Tras la incorporación de la arquitectura RAG y la indexación de la versión completa del Reglamento (UE) 2016/679 en la base vectorial, el asistente pasó a recuperar automáticamente los fragmentos documentales más relevantes para cada consulta. Como resultado, fue capaz de responder correctamente preguntas específicas sobre artículos concretos del GDPR, proporcionando información contextualizada y alineada con la documentación normativa recuperada.

¿Qué establece el artículo 32 del GDPR?

El artículo 32 del GDPR (Reglamento General de Protección de Datos) establece las normas relacionadas con la seguridad del tratamiento de datos personales. A continuación se resumen los puntos clave:

- Medidas de Seguridad:** El responsable y el encargado del tratamiento deben aplicar medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, considerando el estado de la técnica, los costos de aplicación, la naturaleza y el contexto del tratamiento, así como los riesgos para los derechos y libertades de las personas.
- Aspectos a Considerar:** Estas medidas pueden incluir, entre otras, la seudonimización y el cifrado de datos personales.
- Excepciones:** La obligación de aplicar estas medidas no es aplicable en ciertos casos, como:
 - El tratamiento que sea ocasional y no implique el manejo a gran escala de categorías especiales de datos o datos sobre condenas e infracciones penales, que sea improbable que entrañe un riesgo para los derechos y libertades de las personas.
 - Las autoridades u organismos públicos.

Este artículo es fundamental para asegurar que las organizaciones manejen los datos personales con la debida diligencia y seguridad, protegiendo así los derechos de los individuos.

Figura 7: Detalle de la respuesta contextualizada generada por el sistema RAG a partir de la documentación normativa indexada del GDPR.

Esta prueba evidenció la importancia de disponer de documentación normativa completa y correctamente indexada.

4. Fase 3 - Construcción del asistente

4.1 Implementación de la Capacidad 1 - Análisis de políticas de seguridad

La primera capacidad implementada en el asistente consiste en el análisis de documentación relacionada con la seguridad de la información mediante una arquitectura Retrieval-Augmented Generation (RAG). Para ello se construyó una base de conocimiento formada por normativas y evidencias de auditoría que son procesadas, transformadas en embeddings mediante OpenAI Embeddings y almacenadas en una base vectorial (Vector Store).

Cuando el usuario realiza una consulta, el sistema genera una representación semántica de la pregunta y ejecuta una búsqueda sobre la base vectorial para recuperar los fragmentos documentales más relevantes. Esta información se proporciona como contexto al agente de inteligencia artificial, que utiliza modelos GPT de OpenAI para generar respuestas fundamentadas en la documentación previamente indexada.

La implementación se ha realizado mediante un flujo automatizado desarrollado en n8n que integra la carga documental, la generación de embeddings, el almacenamiento vectorial y la recuperación contextual de información. Gracias a esta arquitectura, el asistente puede interpretar requisitos normativos, facilitar el análisis de políticas de seguridad y proporcionar respuestas precisas basadas en documentación oficial.

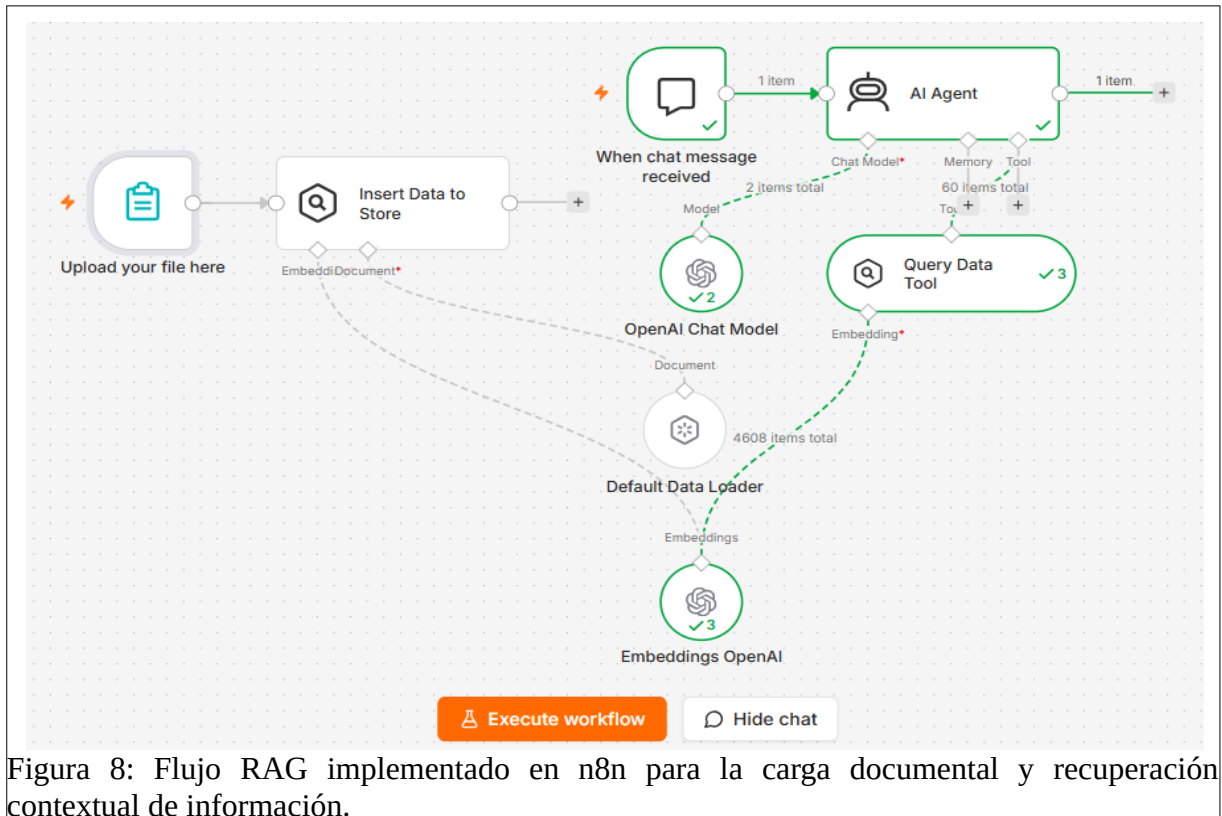


Figura 8: Flujo RAG implementado en n8n para la carga documental y recuperación contextual de información.

4.2 Implementación de la Capacidad 2 - Detección de riesgos e incumplimientos

La segunda capacidad del asistente está orientada a la identificación de riesgos e incumplimientos normativos. Para ello, el sistema permite consultar requisitos específicos contenidos en las normativas ENS, ISO/IEC 27001 y GDPR, facilitando su interpretación y análisis.

Cuando el usuario plantea una situación relacionada con controles de seguridad, medidas de protección o requisitos regulatorios, el asistente recupera la información normativa relevante y genera una respuesta contextualizada basada en la documentación indexada.

Esta capacidad resulta especialmente útil durante actividades de revisión documental, auditoría interna y análisis de cumplimiento, ya que permite localizar de forma rápida referencias normativas relevantes y comprender las obligaciones asociadas a cada requisito.

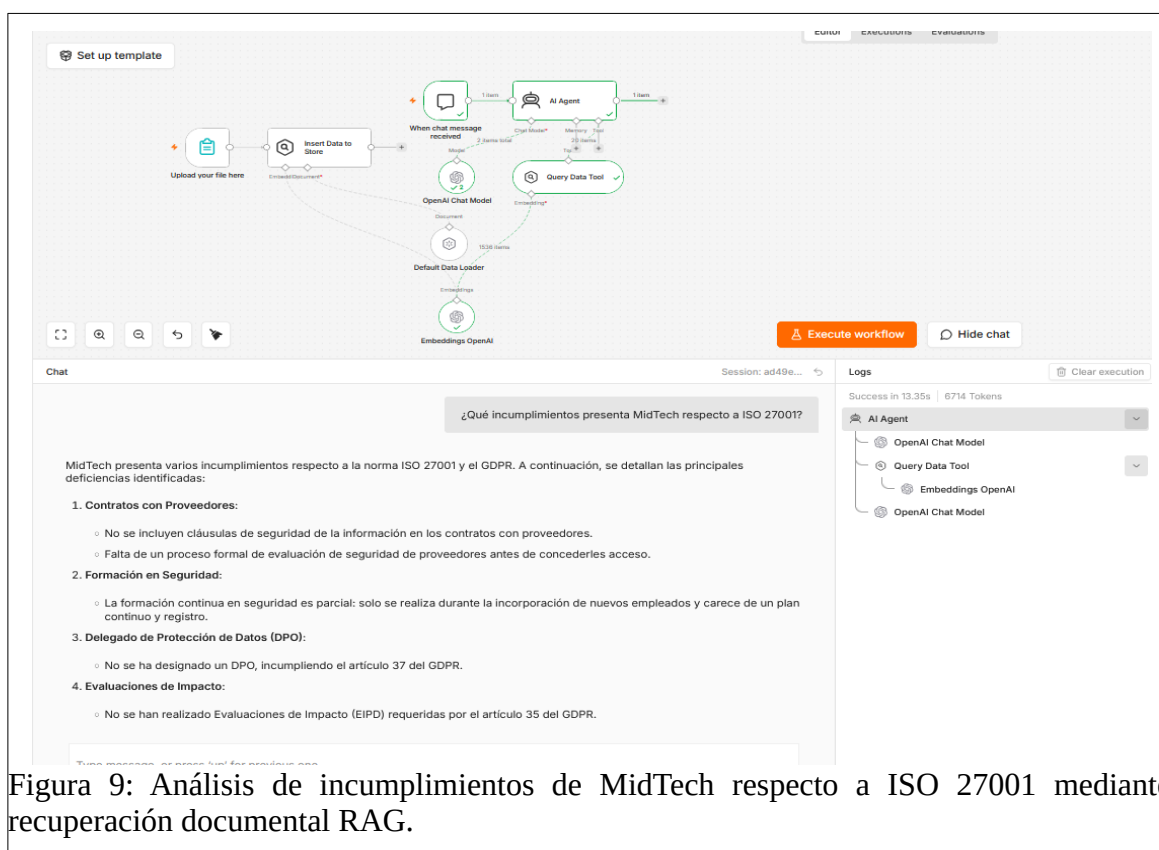


Figura 9: Análisis de incumplimientos de MidTech respecto a ISO 27001 mediante recuperación documental RAG.

La consulta permitió evaluar la situación de MIDTech frente a los requisitos de ISO 27001 utilizando la documentación previamente indexada en la base vectorial. El asistente recuperó la información relevante y generó un listado estructurado de incumplimientos relacionados con gestión de proveedores, formación en seguridad, protección de datos y evaluaciones de impacto.

Esta evidencia demuestra la capacidad del sistema para apoyar tareas de revisión documental y detección de desviaciones respecto a marcos normativos de referencia.

4.3 Implementación de la Capacidad 3 - Respuesta a preguntas de auditoría

La tercera capacidad implementada en el asistente está orientada a la respuesta de consultas relacionadas con procesos de auditoría y verificación de cumplimiento normativo. Esta funcionalidad permite obtener información rápida sobre requisitos, controles y medidas de seguridad recogidas en las normativas incluidas en la base documental.

Durante una auditoría es habitual consultar artículos concretos, verificar requisitos específicos o interpretar controles de seguridad. El asistente facilita estas tareas permitiendo formular preguntas en lenguaje natural y recuperando automáticamente la información normativa relevante.

Esta capacidad contribuye a reducir el tiempo dedicado a la búsqueda manual de información y facilita el acceso a la documentación oficial necesaria para actividades de revisión y auditoría.

The screenshot displays the AI Assistant's workflow and a chat interaction. The workflow diagram at the top shows the process from 'Upload your file here' to 'AI Agent' and 'Query Data Tool'. The chat interface below shows a session with the question '¿Qué establece el artículo 83 del GDPR?' and a detailed response. The response includes a definition of Article 83, a list of administrative fines, criteria for imposing fines, specific infractions, and decisions of the authority. The chat interface also shows a 'Logs' section with a success message and token count.

Chat

Session: ad49e...

¿Qué establece el artículo 83 del GDPR?

El artículo 83 del Reglamento General de Protección de Datos (GDPR) se refiere a las sanciones administrativas que pueden imponerse en caso de infracción. Aquí están sus elementos clave:

- Multas Administrativas:** Establece que las infracciones pueden conllevar multas administrativas, que pueden ser de hasta 20 millones de euros o, en el caso de una empresa, hasta el 4% de su volumen de negocios total anual, lo que sea mayor.
- Criterios para la Imposición de Multas:** El artículo especifica varios factores que deben tenerse en cuenta al determinar la gravedad de la infracción y la medida de la multa, tales como:
 - La naturaleza, gravedad y duración de la infracción.
 - La intencionalidad o negligencia en que se incurrió.
 - Las medidas tomadas para mitigar el daño.
 - El grado de cooperación con la autoridad de control.
 - Los incumplimientos anteriores.
- Infracciones Específicas:** Se determinan diferentes niveles de infracciones, y se pueden imponer multas más altas por infracciones más graves.
- Decisiones de la Autoridad de Control:** La autoridad de control tiene la facultad de imponer las sanciones y debe actuar de manera coherente, considerando las sanciones impuestas en casos similares.

Este artículo destaca la importancia de la protección de datos y establece un marco de responsabilidad para los responsables del tratamiento de datos personales.

Logs

Success in 8.125s | 14.336 Tokens

AI Agent

- OpenAI Chat Model
- Query Data Tool
- Embeddings OpenAI
- OpenAI Chat Model
- Query Data Tool
- OpenAI Chat Model

Figura 10: Respuesta a una consulta de auditoría sobre el artículo 83 del GDPR.

La consulta permitió recuperar información específica sobre el régimen sancionador del artículo 83 del GDPR. El asistente localizó el contenido relevante en la documentación indexada y generó una respuesta contextualizada basada en la normativa oficial. Esta evidencia demuestra la capacidad del sistema para responder consultas de auditoría mediante recuperación documental RAG.

4.4 Implementación de la Capacidad 4 - Propuestas de mejora

La cuarta capacidad implementada en el asistente está orientada a la generación de propuestas de mejora basadas en la documentación normativa disponible en la base de conocimiento. Su objetivo es proporcionar recomendaciones prácticas que ayuden a una organización a mejorar su nivel de cumplimiento respecto a marcos como ENS, ISO/IEC 27001 y GDPR.

Cuando el usuario solicita recomendaciones o acciones de mejora, el sistema recupera la información relevante desde la documentación indexada y genera una respuesta contextualizada basada en los requisitos y controles identificados durante el proceso de recuperación documental.

Las propuestas generadas pueden abarcar aspectos organizativos, técnicos y procedimentales, incluyendo controles de acceso, gestión de incidentes, protección de datos personales, continuidad de negocio o revisión de políticas de seguridad. De este modo, el asistente no se limita a responder consultas normativas, sino que también proporciona orientación para facilitar la toma de decisiones y la mejora continua.

La implementación reutiliza la misma arquitectura RAG empleada en las capacidades anteriores, garantizando que las recomendaciones estén fundamentadas en la documentación normativa incorporada a la base de conocimiento.

The screenshot displays the AI Agent interface. At the top, there's a workflow diagram with steps: 'Upload your file here' (Insert Data to Store), 'When chat message received' (OpenAI Chat Model), 'Query Data Tool', and 'AI Agent'. Below the diagram is a chat window with the session ID 'ad49e...'. The chat history shows a user prompt: 'Propón mejoras prioritarias para que MidTech cumpla los requisitos de ISO 27001 y GDPR.' The AI Agent's response lists four priority improvements for MidTech to comply with ISO 27001 and GDPR:

- Mejoras para cumplir con ISO 27001:**
 - Revisión y auditoría de políticas:** Implementar un proceso de auditoría interna de cumplimiento de las políticas existentes, incluyendo la revisión formal de la política de seguridad de la información anualmente.
 - Desarrollo de controles de acceso:**
 - Implementar autenticación multifactor (MFA) para acceso a sistemas críticos.
 - Revisar y actualizar la política de contraseñas, asegurando que cumpla con estándares más rigurosos.
 - Cifrado de datos:**
 - Asegurar el cifrado de datos en tránsito y en reposo. Documentar la implementación de cifrado para la base de datos de producción.
 - Gestión de incidentes:**
 - Establecer un proceso formal de gestión de incidentes que incluya prácticas de escalamiento y seguimiento de incidentes hasta su resolución.

The right sidebar shows the 'Logs' section with a success message: 'Success in 29.566s | 12,164 Tokens'. The 'AI Agent' section lists the components used: OpenAI Chat Model, Query Data Tool, Embeddings OpenAI, and Default Data Loader.

Figura 11: Propuestas de mejora para MidTech generadas mediante recuperación documental RAG.

La consulta permitió identificar diversas oportunidades de mejora relacionadas con el cumplimiento de ISO/IEC 27001 y GDPR. Entre las recomendaciones propuestas destacan la implantación de autenticación multifactor, la formalización de procesos de gestión de incidentes, la designación de un Delegado de Protección de Datos y la realización de evaluaciones de impacto sobre la protección de datos.

Esta evidencia demuestra la capacidad del asistente para transformar los requisitos normativos recuperados en recomendaciones prácticas y priorizadas que pueden servir como apoyo en procesos de mejora continua y cumplimiento regulatorio.

5. Fase 4 - Demostración y entrega

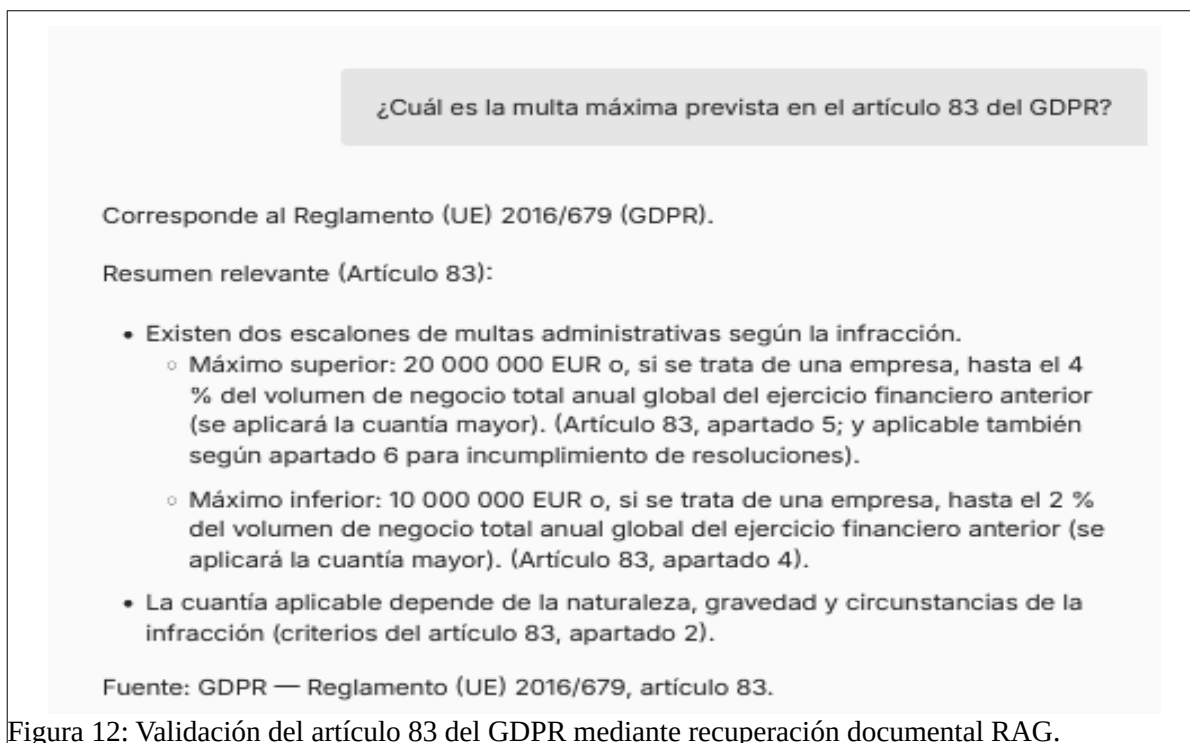
Una vez implementadas las capacidades definidas para el asistente, se realizaron diferentes pruebas funcionales con el objetivo de verificar el correcto funcionamiento del sistema y validar la calidad de las respuestas generadas.

Las pruebas se llevaron a cabo utilizando consultas relacionadas con las normativas ENS, ISO/IEC 27001 y GDPR, verificando el correcto funcionamiento de la arquitectura RAG implementada. Se comprobó la capacidad del sistema para recuperar fragmentos relevantes desde la base vectorial, incorporarlos como contexto y generar respuestas fundamentadas en la documentación normativa indexada.

Durante la fase de validación se detectaron algunas limitaciones relacionadas con la calidad de la documentación utilizada y con la cantidad de contexto proporcionado al modelo de lenguaje. Estas incidencias fueron corregidas mediante la sustitución de documentos incompletos por versiones oficiales y la mejora del proceso de recuperación documental.

Los resultados obtenidos demostraron que el asistente es capaz de responder consultas sobre requisitos normativos, medidas de seguridad, gestión de riesgos, controles de cumplimiento y artículos específicos de las normativas analizadas.

La entrega final del proyecto incluye el flujo implementado en n8n, la documentación normativa utilizada como base de conocimiento, las evidencias de funcionamiento obtenidas durante las pruebas y la documentación técnica desarrollada a lo largo del proyecto.



The screenshot shows a user query in a grey box: "¿Cuál es la multa máxima prevista en el artículo 83 del GDPR?". Below the query, the system response is displayed on a light grey background. It starts with "Corresponde al Reglamento (UE) 2016/679 (GDPR)." followed by "Resumen relevante (Artículo 83):". A bulleted list follows, detailing the two levels of administrative fines: a maximum of 20,000,000 EUR or 4% of global turnover for serious infringements, and a maximum of 10,000,000 EUR or 2% of global turnover for less serious ones. It also states that the applicable amount depends on the nature, gravity, and circumstances of the infringement. The source is cited as "Fuente: GDPR — Reglamento (UE) 2016/679, artículo 83."

¿Cuál es la multa máxima prevista en el artículo 83 del GDPR?

Corresponde al Reglamento (UE) 2016/679 (GDPR).

Resumen relevante (Artículo 83):

- Existen dos escalones de multas administrativas según la infracción.
 - Máximo superior: 20 000 000 EUR o, si se trata de una empresa, hasta el 4 % del volumen de negocio total anual global del ejercicio financiero anterior (se aplicará la cuantía mayor). (Artículo 83, apartado 5; y aplicable también según apartado 6 para incumplimiento de resoluciones).
 - Máximo inferior: 10 000 000 EUR o, si se trata de una empresa, hasta el 2 % del volumen de negocio total anual global del ejercicio financiero anterior (se aplicará la cuantía mayor). (Artículo 83, apartado 4).
- La cuantía aplicable depende de la naturaleza, gravedad y circunstancias de la infracción (criterios del artículo 83, apartado 2).

Fuente: GDPR — Reglamento (UE) 2016/679, artículo 83.

Figura 12: Validación del artículo 83 del GDPR mediante recuperación documental RAG.

6. Reflexión final

El desarrollo de este Trabajo Fin de Curso ha permitido aplicar de forma práctica conocimientos relacionados con la automatización, la inteligencia artificial y el cumplimiento normativo en el ámbito de la ciberseguridad.

Durante las primeras fases del proyecto se planteó una solución basada en la selección directa de documentación normativa. Sin embargo, las pruebas realizadas pusieron de manifiesto diversas limitaciones relacionadas con la capacidad del sistema para interpretar correctamente determinadas consultas y recuperar información específica de forma consistente. Esta situación llevó a replantear parte de la arquitectura inicial e incorporar un enfoque basado en Retrieval-Augmented Generation (RAG).

La incorporación de una base vectorial y de mecanismos de recuperación documental permitió mejorar significativamente la calidad de las respuestas generadas. El asistente pasó de ofrecer respuestas genéricas o ambiguas en determinados casos a proporcionar información contextualizada fundamentada en la documentación normativa incorporada a la base de conocimiento.

A lo largo del proyecto también se comprobó la importancia de la calidad de la documentación utilizada. La actualización de los documentos normativos y la correcta indexación de la información resultaron factores determinantes para obtener respuestas precisas y útiles para tareas de análisis, auditoría y cumplimiento.

Desde una perspectiva personal, este trabajo ha supuesto una oportunidad para profundizar en tecnologías de inteligencia artificial aplicada, comprender el funcionamiento de arquitecturas RAG e integrar diferentes herramientas dentro de un flujo automatizado desarrollado en n8n. Además, ha permitido adquirir experiencia práctica en la validación de resultados, la detección de limitaciones y la mejora iterativa de sistemas basados en modelos de lenguaje.

Como líneas futuras de evolución, el asistente podría ampliarse incorporando nuevas normativas, mecanismos avanzados de evaluación automática del cumplimiento, generación automática de informes y capacidades de integración con repositorios documentales corporativos.

En conclusión, el proyecto ha demostrado la viabilidad de utilizar arquitecturas RAG para construir asistentes especializados en compliance y ciberseguridad capaces de proporcionar respuestas fundamentadas, contextualizadas y alineadas con documentación normativa oficial.

7. Anexos

Los diagramas de arquitectura, capturas de funcionamiento y evidencias de validación utilizadas durante el desarrollo del proyecto se han incorporado directamente en los apartados correspondientes del documento con el fin de facilitar su comprensión y contextualización.

Por este motivo, no se incluyen anexos adicionales independientes.